

Samuel Hailemariam
23 June 2026

Project Overview

A Linux jump host connecting the Tridanium processing plant to the internet was compromised during a national holiday. The response focused on three objectives:

- Detect malware, command-and-control infrastructure, and host indicators.
- Contain access, block the attacker, remove persistence, and secure SSH.
- Scan for vulnerabilities and harden the exposed Apache service.

Final deliverables

- Threat evidence and indicators of compromise
- YARA and iptables controls
- SSH and Apache hardening changes
- Executive-level incident summary



Section 0: Project Scenario

What Are We Doing?

South Udan developed a cleaner Tridanium nuclear-fission process that generates significantly more energy while reducing nuclear waste.

North Udan, still dependent on fossil fuels, sought to disrupt the program through a state-sponsored cyberattack.

Target

Internet-connected Linux jump host

Tridanium processing plant

What Are We Doing?

The National Peace Agency launched the attack during a South Udan national holiday. Password brute forcing against an employee account triggered the initial alarm.

- The attacker obtained SSH access to the jump host.
- A rogue account and root-owned backdoor were created for persistence.
- The host was mission-critical, requiring immediate containment and hardening.
- The investigation started from the compromised jump box.



Section 1: Detection

ClamAV Scan

Command executed: clamscan -r /home/ubuntu/Downloads/

```
/home/ubuntu/Downloads/moni.lod: OK
/home/ubuntu/Downloads/notes.txt: OK
/home/ubuntu/Downloads/SSH-One: OK
/home/ubuntu/Downloads/gates.lod: OK
/home/ubuntu/Downloads/ft32: Unix.Malware.Agent-6774375-0 FOUND
/home/ubuntu/Downloads/ft64: Unix.Malware.Agent-6774336-0 FOUND
/home/ubuntu/Downloads/wipefs: Unix.Tool.Miner-6443173-0 FOUND
/home/ubuntu/Downloads/tmplog: OK
```

```
----- SCAN SUMMARY -----
Known viruses: 8874078
Engine version: 0.100.3
```

Evidence note: the source capture did not preserve the remaining ClamAV summary lines.

Suspicious File Identification

Suspicious file	SSH-One
Callout URL 1	http://darkl0rd.com:7758/SSH-T
Callout URL 2	http://darkl0rd.com:7758/SSH-One

Assessment: SSH-One is a Bash downloader that contacts darkl0rd.com on TCP port 7758 and retrieves additional payloads. It evaded the original ClamAV scan.

YARA Rule Creation

```
rule NPA_Darkl0rd_Domain
{
    meta:
        description = "Detects the darkl0rd.com C2 domain"
        author = "Samuel Hailemariam"
        date = "2026-06-23"
        severity = "high"

    strings:
        $domain = "darkl0rd.com" ascii wide nocase
        $url_ssh_t = "http://darkl0rd.com:7758/SSH-T" ascii nocase
        $url_ssh_one = "http://darkl0rd.com:7758/SSH-One" ascii nocase

    condition:
        $domain or any of ($url_*)
}
```

Validation: `yara npa_darkl0rd_domain.yar /home/ubuntu/Downloads/`

Section 2: Mitigation

Implement HIDS

OSSEC monitored the server while an SSH login was performed. The event view records authentication success and an opened SSH session for ubuntu.

The screenshot displays the OSSEC Web Interface (Version 0.8) running in a Mozilla Firefox browser. The interface includes a sidebar with various icons and a main content area with the following sections:

- Available agents:** +ossec-server (127.0.0.1)
- Latest modified files:** +/etc/resolv.conf, +/etc/subgid-, +/etc/group, +/etc/gshadow, +/etc/gshadow-
- Latest events:**
 - Level:** 3 - Login session closed. **Rule Id:** 5502 **Location:** ubuntu-VirtualBox->/var/log/auth.log **2026 Jun 23 07:03:40**
Jun 23 07:03:39 ubuntu-VirtualBox sshd[7104]: pam_unix(sshd:session): session closed for user ubuntu
 - Level:** 3 - Login session opened. **Rule Id:** 5501 **Location:** ubuntu-VirtualBox->/var/log/auth.log **2026 Jun 23 07:03:28**
Jun 23 07:03:27 ubuntu-VirtualBox sshd[7104]: pam_unix(sshd:session): session opened for user ubuntu by (uid=0)
 - Level:** 3 - SSHD authentication success. **Rule Id:** 5715 **Location:** ubuntu-VirtualBox->/var/log/auth.log **2026 Jun 23 07:03:28**
Src IP: 192.168.56.1
User: ubuntu
Jun 23 07:03:27 ubuntu-VirtualBox sshd[7104]: Accepted password for ubuntu from 192.168.56.1 port 56987 ssh2

At the bottom of the browser window, a Firefox notification states: "Firefox automatically sends some data to Mozilla so that we can improve your experience. Choose What I Share".

Locate Suspicious IP

OSSEC authentication events were reviewed for failed logins followed by successful access and privilege escalation.

Attacker source IP

192.168.56.1

This address is an indicator of compromise for containment and correlation; it is not sufficient by itself for permanent attribution.

IPtables Rule

Block SSH connections from the identified attacker address:

```
sudo iptables -I INPUT 1 -p tcp \  
-s 192.168.56.1 --dport 22 -j DROP
```

Verify and persist the rule:

```
sudo iptables -L INPUT -n --line-numbers  
sudo netfilter-persistent save
```

Detect Username, Process & Port

Backdoor user	darklord
Backdoor process	remotesec
Listening endpoint	0.0.0.0:56565/tcp

- Terminate the process after evidence preservation.
- Lock and remove the rogue account.
- Search systemd, cron, SSH keys, and startup files for persistence.

analysis_image_final [Running] - Oracle VirtualBox

File Machine View Input Devices Help

ubuntu@ubuntu-VirtualBox: ~/Downloads

GNU nano 2.2.6 File: /etc/ssh/sshd_config

```
# Package generated configuration file
# See the sshd_config(5) manpage for details

# What ports, IPs and protocols we listen for
Port 22
# Use these options to restrict which interfaces/protocols sshd will bind to
#ListenAddress ::
#ListenAddress 0.0.0.0
Protocol 2
# HostKeys for protocol version 2
HostKey /etc/ssh/ssh_host_rsa_key
HostKey /etc/ssh/ssh_host_dsa_key
HostKey /etc/ssh/ssh_host_ecdsa_key
HostKey /etc/ssh/ssh_host_ed25519_key
#Privilege Separation is turned on for security
UsePrivilegeSeparation yes

# Lifetime and size of ephemeral version 1 server key
KeyRegenerationInterval 3600
ServerKeyBits 1024

# Logging
SysLogFacility AUTH
LogLevel INFO

# Authentication:
LoginGraceTime 120
PermitRootLogin no
StrictModes yes

RSAAuthentication yes
PubkeyAuthentication yes
#AuthorizedKeysFile      %h/.ssh/authorized_keys

# Don't read the user's ~/.rhosts and ~/.shosts files
IgnoreRhosts yes
# For this to work you will also need host keys in /etc/ssh_known_hosts
RhostsRSAAuthentication no
```

Get Help WriteOut Read File Read 88 lines Prev Page Cut Text Cur Pos
Exit Justify Where Is Next Page UnCut Text To Spell

zorc Sunny 15:30 23/06/2020

Configuration file: /etc/ssh/sshd_config

PermitRootLogin no

Validate with `sudo sshd -t`, reload SSH, and test a second non-root session before closing the current session.

Remote Access & Password Security

- Require MFA for VPN, bastion, privileged, and break-glass access.
- Route administrative SSH through an approved VPN or hardened bastion.
- Disable password authentication after managed key access is tested.
- Use individual accounts, least privilege, sudo, and session logging.
- Rate-limit failed authentication and centralize HIDS and SSH alerts.
- Require long, unique passphrases and block compromised passwords.
- Store credentials in approved password and secrets managers.
- Rotate credentials and revoke keys immediately after compromise.
- Inventory, expire, and remove dormant accounts and stale SSH keys.

Section 3: Hardening

OpenVAS Scan

Report:

Tue, Jun 23, 2026 7:55 PM

Coordinated Universal Time

Done

ID: db9d1132-462f-4243-bd85-674261139ced

Created: Tue, Jun 23, 2026 7:55 PM Coordinated Universal Time

Modified: Tue, Jun 23, 2026 8:24 PM Coordinated Universal Time

Owner: admin

Information

Results

(89 of 89)

Hosts

(1 of 1)

Ports

(2 of 2)

Applications

(4 of 4)

Operating Systems

(1 of 1)

CVEs

(63 of 63)

Closed CVEs

(0 of 0)

TLS Certificates

(0 of 0)

Error Messages

(0 of 0)

User Tags

(0)

<<

>

1 - 10 of 89

>>

Vulnerability

Severity

QoD

Host

Name

Location

EPSS

Created

IP

Score

Percentile

SSH Protocol Versions Supported

0.0 (Log)

95 %

192.168.56.101

22/tcp

N/A

N/A

Tue, Jun 23, 2026 8:01 PM Coordinated Universal Time

Services

0.0 (Log)

80 %

192.168.56.101

22/tcp

N/A

N/A

Tue, Jun 23, 2026 7:59 PM Coordinated Universal Time

Services

0.0 (Log)

80 %

192.168.56.101

80/tcp

N/A

N/A

Tue, Jun 23, 2026 7:59 PM Coordinated Universal Time

OS Detection Consolidation and Reporting

0.0 (Log)

80 %

192.168.56.101

general/tcp

N/A

N/A

Tue, Jun 23, 2026 8:04 PM Coordinated Universal Time

OpenSSH Detection Consolidation

0.0 (Log)

80 %

192.168.56.101

general/tcp

N/A

N/A

Tue, Jun 23, 2026 7:59 PM Coordinated Universal Time

Tue, Jun 23,

Scan date visible: Tuesday, 23 June 2026 at 7:55 PM. The report shows 89 results for host 192.168.56.101, including SSH protocol, exposed service, OS-detection, and OpenSSH findings.

- Validate and prioritize actionable findings.
- Patch supported packages and remove unnecessary services.
- Rescan and document residual risk.

Patching Apache

Current version	Apache HTTP Server 2.4.7
Configuration file	/etc/apache2/conf-available/security.conf

Required banner-hardening settings:

```
ServerTokens Prod
ServerSignature Off
```

- Run `apache2ctl configtest` and reload Apache.
- Verify with `curl -I http://127.0.0.1/`.
- Upgrade Apache through the supported operating-system package channel.

De-Privilege Apache Account

```
sudo groupadd --system apache-group
sudo useradd --system --gid apache-group \
  --no-create-home --shell /usr/sbin/nologin apache-user
sudo chown -R apache-user:apache-group /etc/apache2
```

Configuration file: /etc/apache2/envvars

Replace:
export APACHE_RUN_USER=www-data
export APACHE_RUN_GROUP=www-data

With:
export APACHE_RUN_USER=apache-user
export APACHE_RUN_GROUP=apache-group

Production note: Apache configuration is normally root-owned. Delegate only required writable runtime paths outside this lab requirement.

Executive Summary

- A password-based SSH attack compromised the Tridanium plant's Linux jump host.
- ClamAV identified three malicious tools; manual analysis found an additional downloader contacting darklord.com:7758.
- The attacker used source IP 192.168.56.1 and established persistence with user darklord and the remotesec backdoor on TCP 56565.
- Containment included HIDS validation, firewall blocking, SSH root-login denial, and documented eradication actions.
- OpenVAS and Apache hardening reduced exposed attack surface and service privilege.
- Because a privileged backdoor ran on the host, the safest recovery is rebuild from a known-good image, rotate all exposed credentials, and monitor the identified indicators.

Strategic outcome

Attack contained, persistence identified, and a hardened recovery path defined.